

NMAP MASTERCLASS

¿QUÉ ES NMAP?

Nmap (*Network Mapper*) es la herramienta de **descubrimiento de red y auditoría de seguridad** más usada del mundo. Open-source, gratuita, multiplataforma y mantenida desde **1997** por **Gordon Lyon**

¿PARA QUÉ SIRVE?

Descubrir hosts vivos en una red.

Identificar puertos abiertos y los servicios que escuchan en ellos.

Detectar versiones de servicios (Apache 2.4.41, OpenSSH 8.2p1...).

Detectar el sistema operativo del objetivo (TCP/IP fingerprinting).

Buscar vulnerabilidades conocidas mediante el motor de scripts (NSE).

Auditar firewalls e IDS, mapear arquitecturas de red, inventariar activos.

¿POR QUÉ ES TAN IMPORTANTE EN PENTESTING?

El pentesting sigue una cadena: **Reconocimiento → Enumeración → Explotación → Post-explotación**. Nmap es la herramienta estrella de las **dos primeras fases**. Sin un buen reconocimiento, no hay ataque que valga.

INSTALACION

KALI LINUX

Ya lo tiene, verifica:

```
nmap --version
```

```
(kali㉿kali)-[~]  
$ nmap --version  
Nmap version 7.99 ( https://nmap.org )  
Platform: x86_64-pc-linux-gnu  
Compiled with: liblua-5.4.8 openssl-3.6.3 libssh2-1.11.1 libz-1.3.1 libpcap-  
1.0.4 libpcap-1.10.6 nmap-libdnet-1.18.0 ipv6  
Compiled without:  
Available nsock engines: epoll poll select
```

DEBIAN/UBUNTU

```
sudo apt update  
sudo apt install nmap -y
```

FUNDAMENTOS TEORICOS

Antes de lanzar comandos como un mono con un cuchillo, hay que entender **qué hace Nmap por debajo**.

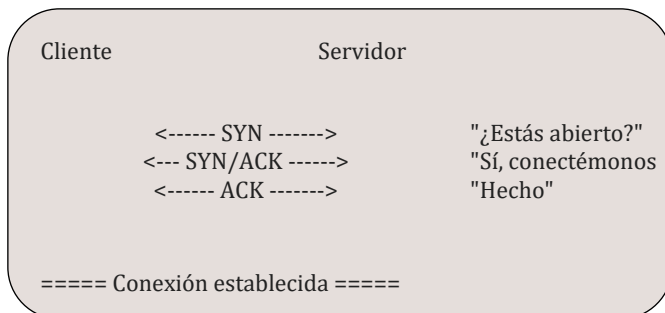
RECORDATORIO TCP/IP

Antes de lanzar comandos como un mono con un cuchillo, hay que entender **qué hace Nmap por debajo**.

Capa	Protocolo	Qué nos importa
Aplicación	HTTP, SSH, FTP, SMB, DNS...	Servicios sobre los que escanearemos
Transporte	TCP, UDP	TCP = orientado a conexión / UDP = no
Red	IP, ICMP	ICMP = ping, TTL, mensajes de error
Enlace	Ethernet, ARP	ARP solo funciona en LAN

TCP THREE-WAY HANDSHAKE

Todo comienza aquí. Cuando dos máquinas hablan TCP:



Nmap aprovecha (y rompe) este handshake para deducir el estado de los puertos.

ESTADO DE LOS PUERTOS EN NMAP

Nmap reporta **6 estados** posibles para cada puerto:

- **open**: Hay un servicio escuchando y aceptando conexiones.
- **Closed**: El puerto responde, pero no hay servicio detrás (host vivo).
- **filtered**: Un firewall/filtro bloquea las sondas. Nmap no puede determinarlo.
- **Unfiltered**: Accesible pero indeterminado (típico de -sA , scan ACK).
- **Open / filtered**: No se puede distinguir (típico de UDP, FIN, NULL, Xmas).
- **Closed / filtered**: Solo posible con -sI (idle scan).

TCP VS UDP SCANNING

TCP es fácil: hay handshake, hay flags, hay respuesta clara.

UDP es duro:

- No hay handshake.
- Si no responde nada → puede ser open o filtered .
- Si responde con ICMP "port unreachable" → closed .
- Es **lentísimo** porque Nmap espera timeouts.

Por defecto Nmap **NO escanea UDP** salvo que se lo pidas con -sU . Pero muchos servicios críticos viven en UDP: DNS (53), DHCP (67/68), SNMP (161), NTP (123), TFTP (69)...

ANATOMIA DE UN COMANDO NMAP

```
nmap [Tipo de escaneo] [Opciones] {especificación de objetivos}
```

Ejemplo completo desglosado:

```
sudo nmap -sS -sV -O -p 1-1000 -T4 -oA escaneo 192.168.1.0/24
```

Parte	Qué hace
sudo	Necesario para escaneos SYN, OS detection, raw sockets
nmap	El binario
-sS	Tipo: TCP SYN scan (stealth)
-sV	Detectar versiones
-O	Detectar SO
-p 1-1000	Puertos del 1 al 1000
0	Velocidad agresiva
-oA escaneo	Salida en los 3 formatos (escaneo.nmap, .gnmap, .xml)
192.168.1.0/24	Toda la subred

ESPECIFICACIÓN DE OBJETIVOS

Nmap es muy flexible para definir **a quién** escaneamos.

HOST UNICO

```
nmap 192.168.1.1
nmap scanme.nmap.org
nmap example.com
```

MULTIPLES HOST

```
nmap 192.168.1.1 192.168.1.5 192.168.1.20
nmap scanme.nmap.org 192.168.1.1
```

RANGO DE IPS

```
nmap 192.168.1.1-50 # del .1 al .50
nmap 192.168.1-3.1-50 # combinación de octetos
```

SUBRED COMPLETA

```
nmap 192.168.1.0/24 # 256 hosts (192.168.1.0 → .255)
nmap 10.0.0.0/16 # 65.536 hosts
```

LISTA DE FICHERO (-iL)

```
echo "192.168.1.1
192.168.1.50
scanme.nmap.org" > targets.txt
nmap -iL targets.txt
```

EXCLUIR HOSTS

```
nmap 192.168.1.0/24 --exclude 192.168.1.1,192.168.1.50
nmap 192.168.1.0/24 --excludefile excluir.txt
```

DESCUBRIMIENTO DE HOSTS

Antes de escanear puertos hay que saber **qué hosts están vivos**. Nmap por defecto hace varias sondas mezcladas. Pero podemos controlarlo:

SOLO DESCUBRIR, NO ESCANEAR PUERTOS (-SN)

```
sudo nmap -sn 192.168.18.0/24
```

```
(kali㉿kali)-[~]
$ sudo nmap -sn 192.168.18.0/24
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-23 06:58 -0400
Nmap scan report for 192.168.18.1
Host is up (0.0016s latency).
MAC Address: 34:58:40:3E:0B:07 (Huawei Technologies)
Nmap scan report for 192.168.18.20
Host is up (0.00031s latency).
MAC Address: B4:2E:99:E8:28:CD (Giga-byte Technology)
Nmap scan report for 192.168.18.29
Host is up (0.058s latency).
MAC Address: B2:4C:BB:B7:F8:71 (Unknown)
Nmap scan report for 192.168.18.44
Host is up (0.00064s latency).
MAC Address: 08:00:27:D1:65:C7 (Oracle VirtualBox virtual NIC)
```

SALTARSE EL DESCUBRIMIENTO

Asume que el host está vivo, aunque no responda al ping. **Útil cuando hay un firewall que descarta ICMP** (clásico de servidores en Internet).

```
nmap -Pn 192.168.1.1
```

```
(kali㉿kali)-[~]
$ sudo nmap -Pn 192.168.18.44
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-23 07:07 -0400
Nmap scan report for 192.168.18.44
Host is up (0.00043s latency).
Not shown: 996 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
3306/tcp  open  mysql
MAC Address: 08:00:27:D1:65:C7 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 1.00 seconds
```

TIPOS DE SONDAS DE DESCUBRIMIENTO

Flag	Sonda	Cuándo usarla
-PE	ICMP Echo (ping clásico)	Redes locales sin firewalls
-PP	ICMP Timestamp	Cuando filtran echo pero no timestamp
-PM	ICMP Address Mask	Algunos routers viejos responden
-PS	TCP SYN ping (puerto X)	Internet, firewalls bloquean ICMP
-PA	TCP ACK ping	Atravesar stateless firewalls
-PU	UDP ping	Sondas raras, evadir reglas TCP-only
-PR	ARP ping (default en LAN)	LAN — siempre, es fiable y rápido

Ejemplos:

```
sudo nmap -PS22,80,443 -sn 192.168.1.0/24    # SYN ping a puertos típicos
sudo nmap -PA80 -sn 192.168.1.0/24          # ACK ping (atraviesa stateless)
sudo nmap -PR -sn 192.168.1.0/24            # ARP en LAN, ultra rápido
```

SIN RESOLUCION DNS (-N)

Ahorra tiempo y no genera tráfico DNS revelador. **Casi siempre lo querrás en redes grandes.**

FORZAR RESOLUCIÓN DNS (-R)

Resuelve incluso para hosts sin respuesta. Útil para inventarios.